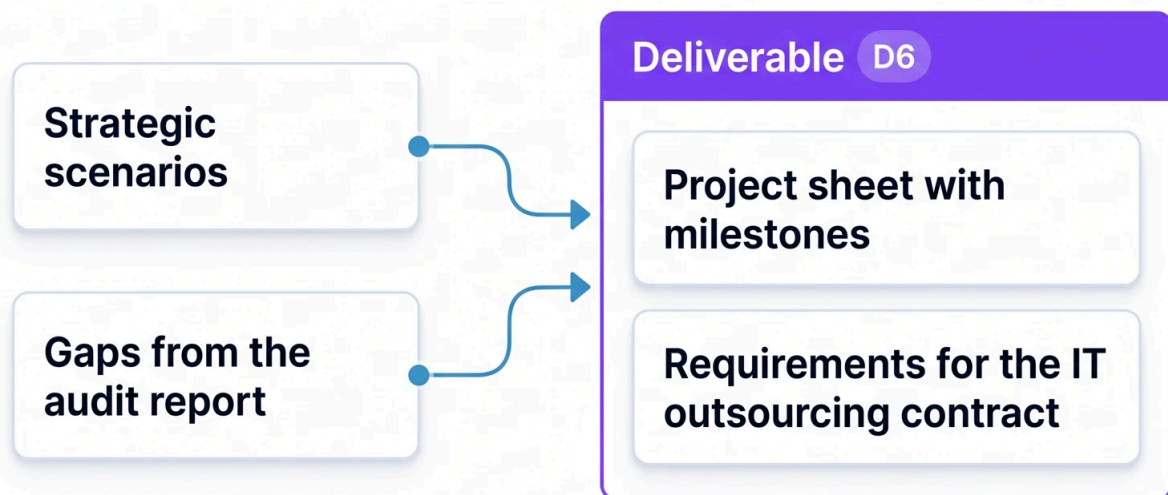


Third-party requirements and project sheet (D6)

From the scenario to the document that commits



Zero orphan requirements

Session objectives

By the end of this lab:

- **Produce** a project sheet equipped with security milestones and verifiable pass criteria
- **Draft** a set of security requirements for an IT outsourcing contract, traced back to the risk analysis
- **Justify** each requirement by a strategic scenario from Workshop 3 or a deviation from the session 4 audit report

- **Enrich** the group's strategy note with its "third parties and projects" subsection

Prerequisites

- The previous lab: the EBIOS RM study enriched with its rated ecosystem, its strategic scenarios and a first operational scenario.
- This morning's lecture: the six security milestones and their pass criteria, the three project regimes.
- The session 4 audit report, whose qualified deviations serve as justification for the requirements.
- The group's strategy note, enriched up to session 5, to be extended at the end of the session.

What is handed in today

Deliverable D6 is made up of two written pieces, consistent with each other, and of the export or screenshot of the EBIOS RM study entered in the previous lab, rated stakeholders and strategic scenarios. A project sheet, which applies Security by Design to a real project of the group. A set of security requirements for an IT outsourcing contract, completed with the third party's monitoring arrangements, which applies third-party control to a real service of the group. The two share one principle: nothing is asserted in them that is not traced back to an identified risk or an observed deviation. A milestone without a pass criterion, or a requirement without a justification, is a wish, and the acceptance grid refuses it.

✓ Piece 1: the project sheet

The project sheet applies Security by Design to a real project of the subsidiary under review, the one the subsidiary pack carries. Frame this project as if it were to be launched today, with the discipline of milestones: each milestone gets a pass criterion demonstrated by a fact, never by a statement. Fill in the two templates below; for a system subject to security authorization, the criterion of milestone M4 is the authorization decision pronounced by the authority designated in session 4. To produce: the complete project sheet, sections and six milestones filled in, each with its verifiable pass criterion and its deliverable.

Template of the project sheet to fill in:

Section	Expected content
Purpose and scope	What the project does, which subsidiaries, which cross-subsidiary flows or flows towards third parties
Data and DICT (availability, integrity, confidentiality, traceability) needs	Data handled, read in the subsidiary pack (patient data, pharmaceutical stock movements, bank details, citizen data, depending on the project), and their needs for availability, integrity, confidentiality, traceability
Project regime	Develop, buy or have developed, and what that choice implies
Security milestones	The six milestones, each with its question and its verifiable pass criterion
Responsibilities	Who owns each milestone, a single ultimate owner per decision (session 1 governance)
Arbitration points	The foreseeable disagreements and the body that decides

For the milestones row, fill in the following table. A verifiable pass criterion is demonstrated by a fact, not by a declaration.

Milestone	Question asked	Verifiable pass criterion	Deliverable produced at the milestone
M1 Qualification	Which data, which DICT needs, which level of analysis?	To be completed	To be completed
M2 Architecture	Segmentation, authentication, logging planned?	To be completed	To be completed
M3 Contracting	Security requirements in the contract, if a third party is involved?	To be completed	To be completed
M4 Acceptance	Requirements demonstrated, not merely declared?	To be completed	To be completed
M5 Operations	Who maintains, monitors, fixes, within what deadlines?	To be completed	To be completed
M6 End of life	Data returned or destroyed, access revoked?	To be completed	To be completed

For a system subject to security authorization, the passing criterion of milestone M4 is the authorization decision, pronounced on the acceptance file by the authority designated in session 4; the sheet says so in so many words.

✓ Piece 2: the requirements for the outsourcing contract

Take up the contract worked on in the tutorial, that of the most exposed provider of the subsidiary under review. Draft the set of security requirements to be written into the specifications of its renewal or amendment, whose coverage the provider will have to demonstrate in its Security Assurance Plan. Each requirement is traced to a strategic scenario of the previous lab, a gap of the session 4 audit, or a silence of the contract recorded in the pack: the justification column is the heart of the exercise. Complete with the arrangements that keep these requirements alive after signature. To produce: the table of traced verifiable requirements and the table of the third party's monitoring arrangements, filled in.

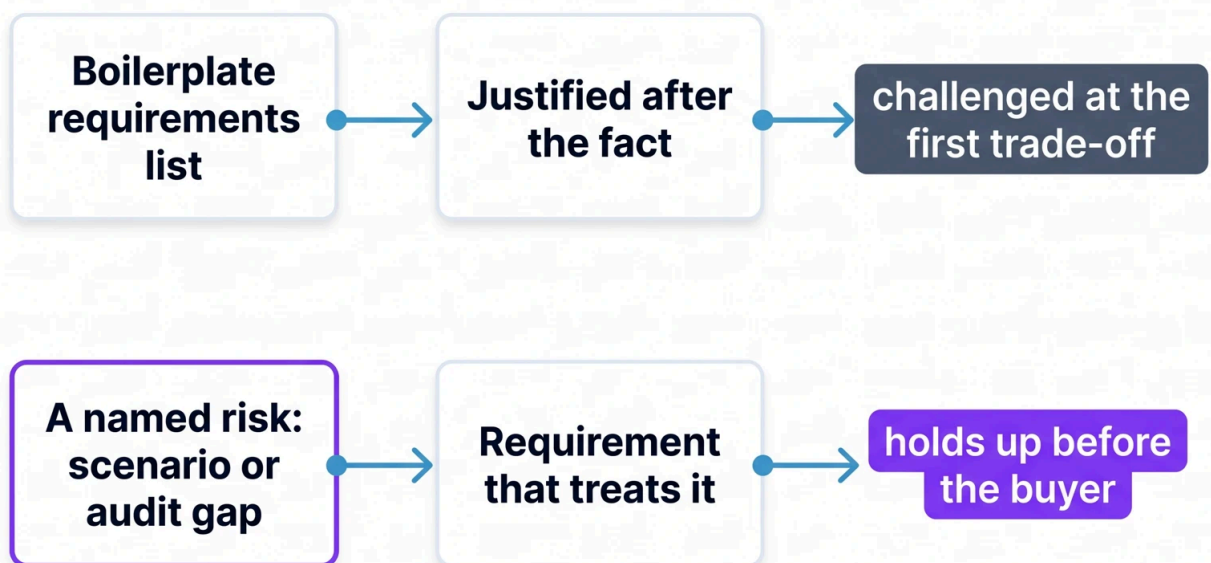
Requirement	Verifiable formulation	Justification (strategic scenario, session 4 audit gap, or a silence of the contract)
Reversibility	To be completed	To be completed
Right to audit	To be completed	To be completed
Incident notification	To be completed	To be completed
Traceability and nominative accounts	To be completed	To be completed
Control of subcontracting	To be completed	To be completed

Complete part 2 with the third party's monitoring arrangements, as deliverable D6 requires: they are what keeps the requirements alive after signature. Fill in this table:

Element of the arrangements	Expected content
Indicator 1	Label, data source, reading frequency
Indicator 2	Same
Indicator 3	Same
Follow-up committee	Frequency, participants, what is decided there
Evidence due every year	What the provider hands over without being asked
What stays with the client	The decisions and checks that are never delegated, even under partial outsourcing

✓ Writing: thirty minutes, two pieces, zero orphan requirement

Allow fifteen minutes per piece and work from the documents, not from memory: the project sheet draws on the session 2 DICT needs and the scenarios of the previous lab, the requirements on the session 4 audit and the tutorial's contract. For the project sheet, start with milestone M1; for the requirements, start from the strategic scenario and work back to the requirement, never the other way round. A requirement without a justification is worth nothing.



✓ Strategy note (15 minutes)

Last quarter of an hour, the module's ritual: enrich the group's strategy note with a sixth subsection, "third parties and projects", half a page at most, without copying anything from D6. It carries the group's position on its third parties and its projects and explicitly links to the subsections of the previous sessions, the governance of session 1 and the critical assets of session 2. The constraints remain: three to five pages of text in total, tables and appendices not counted, nothing is deleted, everything is amended with a sentence of justification. To produce: the "third parties and projects" subsection, linked to the earlier subsections and fitting within the overall length.

Target governance
(session 1)

Critical assets
(session 2)

Major risks
(session 5)

Subsection
"Third parties
and projects"



Answer keys and assessment criteria – cliquer pour révéler